

Compliance Audit: Acme Corporation

Company:	Acme Corporation	Audit Standard:	EU GDPR (Regulation 2016/679)
Policy Document:	Global Privacy Policy	Audit Date:	August 17, 2026
Evaluated Groups:	4	Risk Level:	MEDIUM RISK

Overall Compliance Summary

75.0%	2	2	0	0	0
Compliance Score	Fully Met	Partially Met	Not Met	Conflicting	Insufficient Evidence

Executive Overview

This GDPR Compliance Audit evaluated **4 requirement groups** spanning **4 sub-obligations** across the General Data Protection Regulation. The assessment determined an overall compliance posture of **75.0%** with a designated risk classification of **MEDIUM RISK**.

Key Audit Findings:

- **Fully Satisfied:** 2 requirement groups clearly demonstrated compliance.
- **Partial Gaps:** 2 requirement groups exhibit partial policy coverage requiring formal procedural additions.
- **Non-Compliant / Unaddressed:** 0 requirement groups lacked mandatory policy disclosures or operational commitments.
- **Conflicting Directives:** 0 groups contain policy language directly contradicting GDPR standards.

Chapter-by-Chapter Compliance Breakdown

Structured view of compliance readiness across the 11 GDPR thematic chapters.

Chapter	Chapter Name	Articles	Evaluated Groups	Status
Chapter I	General Provisions	Art. 1–4	0	No Direct Obligation Groups
Chapter II	Principles	Art. 5–11	4	PARTIALLY MET
Chapter III	Rights of the Data Subject	Art. 12–23	0	No Direct Obligation Groups
Chapter IV	Controller and Processor	Art. 24–43	0	No Direct Obligation Groups
Chapter V	Transfers of Personal Data to Third Countries	Art. 44–49	0	No Direct Obligation Groups
Chapter VI	Independent Supervisory Authorities	Art. 51–59	0	No Direct Obligation Groups
Chapter VII	Co-operation and Consistency	Art. 60–76	0	No Direct Obligation Groups
Chapter VIII	Remedies, Liability and Penalties	Art. 77–84	0	No Direct Obligation Groups
Chapter IX	Specific Processing Situations	Art. 85–91	0	No Direct Obligation Groups
Chapter X	Delegated Acts and Implementing Acts	Art. 92–93	0	No Direct Obligation Groups
Chapter XI	Final Provisions	Art. 94–99	0	No Direct Obligation Groups

Detailed Requirement Gap Analysis

Granular sub-obligation verdicts grounded in retrieved policy evidence.

Group 5.1.f — Integrity and confidentiality (Article 5) | MET (Confidence: 95%)

Obligation ID	Verdict & Confidence	Reason & Evidence Quote
5.1.f.1	MET Conf: 95%	Analysis: Policy explicitly states implementation of industry-standard technical measures (TLS 1.3 encryption in transit, AES-256 encryption at rest) and organizational measures (MFA access control, quarterly audits, annual penetration testing) to protect against unauthorized access, loss, or damage. <i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:9):</i> "We implement industry-standard technical and organisational measures to protect your personal data against unauthorised access, loss, destruction, or alteration. - All data in transit is encrypted using TLS 1.3 - All data at rest is encrypted using AES-256 - Access to production systems is restricted to authorised personnel only via MFA - We conduct quarterly internal security audits - Penetration testing is conducted annually by a third-party security firm"

Group 5.1.quality_retention — Accuracy and storage limitation (Article 5) | PARTIALLY_MET (Confidence: 75%)

Identified Gap / Finding: Policy provides right to correction but lacks explicit 'prompt' timeframe. Retention periods are defined with legal exceptions but safeguards for extended retention are not explicitly stated.

Obligation ID	Verdict & Confidence	Reason & Evidence Quote
5.1.quality_retention.1	PARTIALLY_MET Conf: 75%	Analysis: Policy provides right to correction but lacks explicit 'prompt' timeframe. Retention periods are defined with legal exceptions but safeguards for extended retention are not explicitly stated. <i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:6):</i> "If any personal data we hold about you is inaccurate or incomplete, you may request that we correct or update it." <i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:4):</i> "We retain personal data only for as long as necessary to fulfil the purposes outlined in this policy."

Group 5.1.handling — Lawfulness, fairness, transparency, purpose limitation and minimisation (Article 5) | MET (Confidence: 92%)

Obligation ID	Verdict & Confidence	Reason & Evidence Quote
5.1.handling.1	MET Conf: 92%	Analysis: Policy explicitly states lawful bases (contractual, legitimate interests, legal obligation, consent), transparent handling (consent withdrawal rights), specific purposes (fraud prevention, security, product improvement), and compatibility of processing. Data minimization is addressed through retention policies. <i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:3):</i> "We process personal data only when we have a valid legal basis to do so. The legal bases we rely on are: Contractual necessity, Legitimate interests, Legal obligation, Consent." <i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:3):</i> "Consent — for marketing communications and optional analytics (you can withdraw at any time)" <i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:3):</i> "We do not further process in a manner incompatible with those purposes" <i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:4):</i> "We retain personal data only for as long as necessary to fulfil the purposes outlined in this policy"

Group 5.2 — Accountability (Article 5) | PARTIALLY_MET (Confidence: 65%)

Identified Gap / Finding: Policy mentions data retention periods and legal bases for processing, which support accountability. However, there is no explicit evidence of records or documentation demonstrating compliance with Art. 5(1).

Obligation ID	Verdict & Confidence	Reason & Evidence Quote
5.2.1	PARTIALLY_MET Conf: 65%	Analysis: Policy mentions data retention periods and legal bases for processing, which support accountability. However, there is no explicit evidence of records or documentation demonstrating compliance with Art. 5(1). <i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:5):</i> "Transaction records and invoices are retained for 7 years in compliance with Indian tax laws..." <i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:4):</i> "We retain personal data only for as long as necessary to fulfil the purposes outlined in this policy."

Priority Action Plan & Remediation Guidance

Categorized recommendations based on identified compliance gaps.

Priority Level	GDPR Article	Group ID	Required Remediation Action
P2 HIGH	Article 5	5.1.quality_retention	Policy provides right to correction but lacks explicit 'prompt' timeframe. Retention periods are defined with legal exceptions but safeguards for extended retention are not explicitly stated.
P2 HIGH	Article 5	5.2	Policy mentions data retention periods and legal bases for processing, which support accountability. However, there is no explicit evidence of records or documentation demonstrating compliance with Art. 5(1).